



**RÉPUBLIQUE
FRANÇAISE**

*Liberté
Égalité
Fraternité*



ANALYSE DE RISQUE DE HAUT NIVEAU SUR LE CHIFFREMENT ET AUTRES USAGES DE LA CRYPTOGRAPHIE



ANALYSE DE RISQUE DE HAUT NIVEAU SUR LE CHIFFREMENT ET AUTRES USAGES DE LA CRYPTOGRAPHIE

L'ensemble des organisations de tous secteurs confondus, publiques ou privées, sont vulnérables à la menace que fait peser l'arrivée de l'ordinateur quantique. Or, nombre d'entre elles se sentent encore peu concernées par les risques qu'elle engendre¹, et ne perçoivent ni l'urgence, ni la nécessité de lancer leur migration. Il ne s'agit cependant plus de savoir si elles sont menacées mais quand et comment elles peuvent se protéger. L'enjeu est double : d'une part, amener toutes les organisations à engager rapidement leur transition post-quantique ; d'autre part, amplifier l'incitation des fournisseurs à faire évoluer leurs offres pour garantir la mise à disposition de produits PQC de confiance sur le marché.

Cette analyse de risque de haut niveau sur le chiffrement et autres usages de la cryptographie s'adresse aux entités utilisatrices de solutions cryptographiques, mais non spécialistes du domaine. Elle complète la documentation déjà disponible en France et à l'international, principalement destinée aux experts et aux fournisseurs.

Ce document présente un panorama des risques et des impacts métiers. Il propose une méthode simple de priorisation et des recommandations associées immédiatement actionnables. Des compléments en annexe fournissent un glossaire et détaillent la méthode de priorisation en proposant des critères d'évaluation pour guider les organisations. Ce document est une incitation pour tous les décideurs à passer à l'action pour construire leur stratégie de transition post-quantique dès maintenant.

¹ Etat de la prise en compte de la cryptographie post-quantique : https://cyber.gouv.fr/documents/344/20241114_np_anssi_PQC3.pdf

Panorama général

La cryptographie est omniprésente dans notre environnement numérique. Elle protège les échanges sur Internet, les paiements en ligne, les communications mobiles, les mises à jour logicielles, les données stockées dans le cloud, ainsi que l'authentification des personnes et des équipements. Invisible pour la plupart des utilisateurs, elle constitue pourtant un socle essentiel de confiance, garantissant la confidentialité des informations, l'intégrité des données et l'authenticité des entités (personne ou machine).

Cependant, la solidité de ces mécanismes cryptographiques pourrait être remise en cause dès demain par le développement de nouvelles technologies, notamment des ordinateurs quantiques². Ces derniers permettraient de résoudre certains problèmes mathématiques ciblés beaucoup plus rapidement que des ordinateurs classiques et seraient capables de casser des algorithmes de cryptographie asymétrique. Dans un contexte de rivalité technologique croissante entre grandes puissances, ces nouvelles capacités constituent une menace pour la sécurité nationale, en fragilisant l'ensemble des systèmes fondés sur le chiffrement.

Si l'ordinateur quantique n'est pas opérationnel aujourd'hui, cette réalité ne doit pas conduire à différer la mise en œuvre des mesures de protection. D'une part, certaines attaques rétroactives³, fondées sur le stockage actuel de données en vue d'une exploitation future, peuvent être engagées dès à présent. D'autre part, le temps de la migration post-quantique d'une organisation est estimé à environ dix ans. Il est donc essentiel que les organisations commencent à construire leur stratégie de transition post-quantique immédiatement, afin d'achever la migration de leurs actifs les plus critiques avant l'apparition de l'ordinateur quantique. Elles s'exposeront sinon à de nombreux risques : atteinte à la confidentialité des données, à leur intégrité, et fragilisation des mécanismes d'authentification reposant sur des signatures ou des certificats.

Face aux menaces actuelles et futures, et en tenant compte de la complexité de la migration des actifs⁴, il est essentiel de commencer la transition vers une cryptographie résistante à la menace quantique, dite post-quantique⁵ (PQC), dès maintenant.

² Aussi appelés CRQC (*Cryptographically Relevant Quantum Computers*), ils permettent de mener des cryptanalyses pertinentes en particulier pour la cryptographie asymétrique, aujourd'hui très largement déployés dans l'établissements de clé et signatures RSA, dans les échanges de clés EC-DH, et dans les signatures EC-DSA.

³ Les attaques rétroactives, dites « *store now, decrypt later* » consistent à intercepter des données chiffrées dans le but de les décrypter une fois les capacités de calcul nécessaires disponibles.

⁴ Dans ce document, les « actifs » sont les données, les systèmes et équipements et les mécanismes cryptographiques qui peuvent être concernés par la migration post-quantique.

⁵ La PQC, ou « *post-quantum cryptography* », est, pour l'ANSSI, la voie la plus prometteuse pour se prémunir contre la menace quantique.

L'enjeu n'est pas seulement technologique, mais stratégique. La migration des actifs vers des solutions de PQC doit être anticipée et suivie par la gouvernance des organisations. Elle implique des transformations longues et complexes des systèmes d'information, des produits et des infrastructures. Attendre que la menace soit pleinement concrète exposerait les organisations à un risque majeur immédiat de perte de confidentialité, d'intégrité et de confiance.

Principaux risques métiers

En remettant en cause les fondements des systèmes cryptographiques historiques, essentiels aux besoins de sécurité des organisations, la menace quantique affecte trois piliers : la protection des informations sensibles et des communications (confidentialité), la garantie que les données ne sont pas altérées (intégrité) et la preuve de l'identité des entités ou de l'origine des données (authentification).

Confidentialité	→	garder secret
Intégrité	→	garantir l'exactitude
Authentification	→	prouver la légitimité

Du point de vue métier, la compromission de ces fonctions cryptographiques par des capacités de calcul quantiques entraîne cinq risques principaux, décrits ci-après, dont les conséquences pourraient être critiques.

Risque 1 : Décryptement rétroactif de données

- **Objectif de cybersécurité impacté** : Confidentialité des données.
- **Type de scénario possible** : Les attaques rétroactives, dites « *store now, decrypt later* », consistent à collecter des données chiffrées lorsqu'elles sont en transit dans un canal de communication chiffré ou à les voler lorsqu'elles sont stockées chiffrées au repos. Elles sont ensuite stockées dans le but de les décrypter⁶ une fois les capacités quantiques des attaquants opérationnelles.
- **Explication du mécanisme de cryptographie concerné** : De nombreux systèmes actuels utilisent des mécanismes de chiffrement ou d'établissement de clés asymétriques⁷. Si ceux-ci reposent sur des problèmes mathématiques considérés comme difficiles à résoudre avec les moyens de calcul conventionnels, ils sont particulièrement vulnérables à la menace quantique.
- **Conséquences concrètes** : Ce type d'attaques nécessite des moyens importants (collecte, stockage, décryptement), majoritairement à disposition d'acteurs étatiques et s'inscrit dans un temps long. Elles servent des objectifs stratégiques d'espionnage relevant plutôt de la sphère étatique (gouvernementale,

⁶ Le déchiffrement et le décryptement sont deux notions proches mais distinctes. Le déchiffrement consiste à transformer des données chiffrées en données intelligibles à l'aide de la clé de déchiffrement, tandis que le décryptement consiste à retrouver des données intelligibles à partir de données chiffrées sans disposer de la clé légitime.

⁷ « En cryptographie asymétrique, au lieu de faire reposer la sécurité sur un secret partagé, c'est-à-dire n'avoir qu'une seule clé comme c'est le cas en cryptographie symétrique, on dispose d'un couple de clés que l'on appelle bi-clé. L'une d'elle est privée et l'autre publique et ce qui est chiffré avec la clé publique ne peut être déchiffré qu'avec la clé privée. A la différence de la clé publique, cette dernière doit par définition rester secrète et ne pas quitter son propriétaire. » : <https://cyber.gouv.fr/crypto-le-webdoc/chapitre-ii-crypto-sensu/>.

diplomatique, économique ou industrielle), mais peuvent également concerner des organisations privées détenant des données à forte valeur stratégique. Les acteurs exposés à ces menaces doivent dès maintenant lancer des actions pour limiter leur durée d'exposition. Ce risque concerne donc, dans un premier temps, des informations sensibles à longue durée de vie, telles que des secrets d'État, des données de recherche et développement industrielles, des contrats commerciaux confidentiels (fusions-acquisitions, appels d'offres), des données de santé ou encore des communications stratégiques sensibles. En raison de leur temporalité, seules les données sensibles présentant une valeur durable sont aujourd'hui particulièrement exposées par ce scénario de risque.

Risque 2 : Décryptement en temps réel de données

- **Objectif de cybersécurité impacté** : Confidentialité des données.
- **Type de scénario possible** : Un acteur malveillant disposant des capacités quantiques pourrait collecter ou intercepter des données chiffrées et les décrypter en temps réel.
- **Explication du mécanisme de cryptographie concerné** : De nombreux systèmes actuels utilisent des mécanismes de chiffrement ou d'établissement de clés asymétriques, particulièrement vulnérables à la menace quantique.
- **Conséquences concrètes** : Les organisations n'ayant pas engagé leur transition vers des solutions post-quantiques, ou n'ayant pas achevé la migration de leurs actifs exposés, s'exposeront à un risque direct de compromission et de déchiffrement de données stratégiques et d'informations sensibles. Si cette menace n'est pas active aujourd'hui, des mesures doivent d'ores et déjà être mises en œuvre pour s'y préparer ; en effet, la durée estimée d'une migration post-quantique s'élève à dix ans.

Risque 3 : Falsification de documents signés

- **Objectif de cybersécurité impacté** : Intégrité des données.
- **Type de scénario possible** : Un attaquant possédant des capacités quantiques pourrait usurper l'identité d'un utilisateur légitime en falsifiant des signatures. Il pourrait également modifier des données dont l'intégrité et l'origine sont garanties par des signatures vulnérables ou créer des documents frauduleux.
- **Explication du mécanisme de cryptographie concerné** : Les mécanismes de signature numérique classiques reposent sur de la cryptographie asymétrique, vulnérable à la menace quantique.
- **Conséquences concrètes** : Un acteur malveillant serait en mesure de produire de faux documents signés, compromettant ainsi la validité des archives et des actes juridiques (par exemples, des contrats, des actes notariés, des documents administratifs ou de santé, des preuves ou des archivages, dont la validité peut

se compter en dizaines d'années). La possibilité de produire frauduleusement des signatures numériques validerait les chaînes d'authentification et altérerait la confiance dans les échanges dématérialisés. La capacité à discriminer les documents authentiques des documents illégitimes serait alors entravée, impactant particulièrement les données dont l'intégrité est garantie par des signatures à longue durée de vie. Cela affecterait directement les processus juridiques, administratifs et contractuels. La pérennité des preuves serait aussi menacée par un attaquant qui pourrait contester ou falsifier a posteriori des documents archivés aujourd'hui, car leur altération serait difficilement prouvable.

Risque 4 : Prise de contrôle d'équipements aux longs cycles de vie

- **Objectif de cybersécurité impacté** : Authentification des utilisateurs, confidentialité des données et intégrité des systèmes.
- **Type de scénario possible** : Un acteur malveillant disposant de capacités suffisantes pourrait compromettre les mécanismes d'authentification d'un système afin d'en prendre le contrôle et d'accéder aux données qu'il traite.
- **Explication du mécanisme de cryptographie concerné** : Les systèmes embarqués, comme ceux des satellites ou des sondes spatiales, et les systèmes industriels reposent pour partie sur des mécanismes immuables pour plusieurs décennies. L'authentification sur ces équipements repose généralement sur des mécanismes cryptographiques asymétriques, l'équipement embarquant une clé privée lui permettant de prouver son identité mais aussi toutes les clés publiques des opérateurs autorisés à s'authentifier. Comme tous les mécanismes asymétriques, ce fonctionnement est vulnérable à la menace quantique. Une fois authentifié, un attaquant pourrait ensuite accéder aux données stockées sur ces équipements, voire prendre le contrôle du système.
- **Conséquences concrètes** : Un attaquant capable de retrouver la clé privée pourrait usurper l'identité de l'équipement ou du centre de contrôle, envoyer de fausses commandes légitimées ou intercepter des communications en se faisant passer pour une entité de confiance. La prise de contrôle du système pourrait mettre en péril l'équipement en lui-même et ses missions. Sur le plan physique, par exemple dans le cas d'un système d'assainissement de l'eau, une défaillance du matériel pourrait entraîner des risques sanitaires et environnementaux. La compromission d'un système ne pouvant pas être mis à jour serait durable et irréversible, avec des impacts potentiellement critiques : perte de contrôle, altération de mission, indisponibilité du service, voire mise en danger d'infrastructures dépendantes.

Risque 5 : Attaque par la chaîne d'approvisionnement

- **Objectif de cybersécurité impacté** : Confidentialité des données, intégrité des données et des systèmes, authentification des utilisateurs, voire disponibilité des systèmes et des données.
- **Type de scénario possible** : Un attaquant disposant de technologies quantiques pourrait cibler une organisation en exploitant les failles de l'un de ses fournisseurs.
- **Explication du mécanisme de cryptographie concerné** : La compromission d'un tiers n'ayant pas terminé sa propre transition post-quantique pourrait entraîner un nivellement du niveau de sécurité par le bas et permettre à un acteur malveillant de réaliser une attaque contre une entité ayant pourtant fini la migration de ses propres équipements.
- **Conséquences concrètes** : Selon le type d'attaque, les conséquences peuvent être variées et entraîner, entre autres, l'accès à des données confidentielles, la prise de contrôle d'un système, l'atteinte à des mécanismes d'authentification, voire l'indisponibilité de certains équipements. A titre d'exemple, un attaquant pourrait mener une attaque par la chaîne d'approvisionnement logicielle en usurpant l'identité d'un éditeur légitime et en utilisant sa signature sur du code malveillant⁸, exploitant ainsi les failles des mécanismes de signature numérique classiques décrites dans le deuxième risque.

Au-delà des actes malveillants, une mauvaise gouvernance de l'organisation peut créer des fragilités génératrices de risques, pouvant menacer l'ensemble des objectifs de cybersécurité.

La protection des actifs sensibles repose sur des mécanismes cryptographiques dont la robustesse dépend du choix d'algorithmes éprouvés et de la bonne gestion des clés et certificats. C'est pourquoi, un maintien en condition de sécurité insuffisant, le recours à des pratiques non maîtrisées (comme du shadow IT¹), l'utilisation de standards non éprouvés ou encore d'algorithmes vulnérables augmentent significativement les risques d'accès non autorisé, de compromission de données et de perte d'intégrité. De plus, le recours à des pratiques non maîtrisées empêche l'établissement d'un inventaire cryptographique complet.

De même, une mauvaise prise en compte des enjeux de compatibilité au sein de l'entité et vis-à-vis de ses fournisseurs lors de la migration pourrait entraîner des interruptions de service.

⁸ Dans la même logique que dans l'attaque SolarWinds hack dans laquelle un code malveillant a été signé avec un certificat légitime, puis diffusé comme une mise à jour officielle. Mais ici, la signature est falsifiée grâce à une rupture du mécanisme de signature lui-même, et non en utilisant une clé obtenue illicitement.

Processus stratégique de transition post-quantique

Toute organisation doit préparer et conduire sa transition post-quantique en s'appuyant sur une stratégie structurée, définissant les étapes clés de la migration des actifs, et assurant leur mise en œuvre dans la durée. Cette transition post-quantique s'articule en quatre étapes :

- 1. Evaluation de la criticité de l'entité** : Cette phase d'analyse permet d'apprécier l'exposition de l'organisation aux risques identifiés, d'évaluer la criticité des activités et des données traitées, de recenser ses dépendances internes ou externes (il peut s'agir, entre autres, de dépendances à des fournisseurs, des produits, ou des dépendances logicielles.) et d'inventorier les actifs et leur durée de vie. Cette étape doit également permettre d'identifier les obligations réglementaires auxquelles l'entité doit répondre ;
- 2. Construction de la stratégie de transition post-quantique** : Cette stratégie doit permettre de déterminer avec les experts les étapes clés de la transition et de prioriser les actifs en s'appuyant sur la méthode décrite ci-après ;
- 3. Mise en œuvre de la stratégie de transition post-quantique** : Cette phase correspond au déroulement de la feuille de route prévue. Elle permet notamment de mener des phases de tests, d'identifier d'éventuelles erreurs et de prévoir des retours en arrière si nécessaire ;
- 4. Gouvernance continue de la cryptographie** : La transition post-quantique d'une entité peut être longue, et nécessite l'instauration d'une gouvernance active et durable des systèmes de cryptographie mis en place, afin de suivre la mise en œuvre de la stratégie de transition post-quantique et de la mettre à jour si besoin. Compte tenu de la criticité des conséquences en cas de non-migration d'actifs, le sujet s'inscrit naturellement dans le périmètre de la gouvernance haute de l'organisation (comité de direction, conseil d'administration, comité des risques, etc.), et trouve ainsi sa place dans la feuille de route de l'entité, avec une intégration progressive au gré des renouvellements de marchés.

Méthode de priorisation

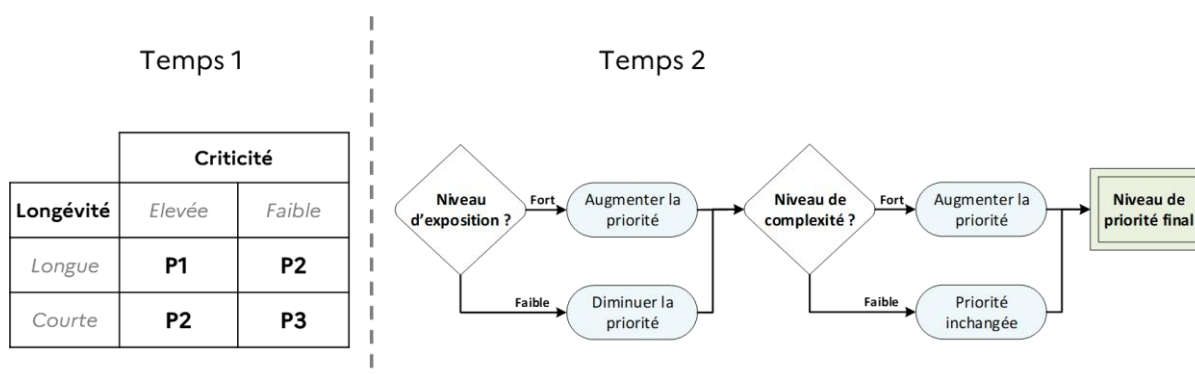
Les actifs (équipements, données ou mécanismes cryptographiques) doivent être priorisés par cas d'usage au regard des risques identifiés. Cette priorisation peut être guidée par les critères décrits en Annexe 2 de ce document. La méthode proposée se déroule en deux temps :

Temps 1 : Evaluer le niveau de priorité en fonction de deux critères principaux :

- **la criticité des actifs** : elle augmente selon la gravité des conséquences de leur compromission, et du niveau de sensibilité des données qu'ils traitent ;
- **la longévité des actifs** : plus la durée de conservation d'une donnée est longue, plus celle-ci doit être prioritaire, en raison des attaques rétroactives. De même, plus la durée de vie d'un système est longue, plus celui-ci devra être prioritaire, à moins qu'il ne puisse facilement être mis à jour.

Temps 2 : Ajuster le niveau de priorité selon deux autres critères :

- **l'exposition des données ou du système** : le niveau de priorité augmente s'ils sont accessibles à distance sans mécanisme d'authentification post-quantique par exemple ;
- **la complexité de la migration de l'actif** : plus la migration d'un actif est longue et nécessite de moyens, plus le niveau de priorité augmente.



Méthode de priorisation en deux temps

Le niveau de priorité des actifs va de P1, les plus prioritaires et dont la migration vers la PQC est à débiter immédiatement, à P3, les moins prioritaires.

Recommandations

Les recommandations ci-dessous visent à accompagner tous les acteurs, quel que soit leur secteur et quelle que soit leur taille, dans leur processus pour réaliser et conduire une stratégie de transition post-quantique. Ces recommandations s'appliquent également dans le cas où tout ou partie du processus est externalisé.

Cette liste de recommandations n'a pas vocation à être exhaustive et vient en complément des publications techniques de l'ANSSI. Pour aller plus loin, des ressources documentaires sont disponibles en annexe du présent document.



Niveau Décideur



Niveau RSSI



Niveau technique



Extérieur
/Partenaire

1. Evaluation de la criticité de l'entité



R01. Identifier les réglementations s'appliquant à l'organisation qui exigent l'utilisation de PQC.



R02. Réaliser un inventaire des actifs (données, systèmes, mécanismes cryptographiques) et de leurs dépendances en estimant leur criticité ainsi que leur durée de vie. Cette phase d'inventaire, souvent complexe et particulièrement longue dans les systèmes d'information étendus ou historiques, ne doit pas être sous-estimée. Toutefois, il n'est pas nécessaire que cet inventaire soit exhaustif et finalisé pour commencer à appliquer les recommandations ci-après.



R03. Réaliser une analyse de risque de l'entité afin d'identifier et d'évaluer les risques liés à la menace quantique auxquels elle est exposée. Il est possible de s'appuyer sur les analyses de risques existantes, qui peuvent déjà mentionner certaines mesures de chiffrement.

2. Construction de la stratégie de transition post-quantique



R04. Prioriser la migration des actifs selon la méthode décrite précédemment et en prenant en compte l'inscription dans le cycle classique de renouvellement des systèmes d'information.



R05. Saisir l'opportunité de la transition post-quantique pour l'intégrer dans une stratégie plus large de sécurité, consolider la cartographie des actifs et renforcer les process de gouvernance.



R06. Identifier les équipements devant être mis à jour et contacter les fournisseurs pour connaître leur feuille de route.

-  R07. Identifier les délais de renouvellement des solutions intégrant de la cryptographie et prévoir un calendrier de renouvellement progressif avec des solutions incluant de la PQC.
-  R08. Identifier les besoins nouveaux (équipements complémentaires, changements d'infrastructure, compétences ou savoir-faire).
-   R09. Planifier le budget nécessaire pour la transition post-quantique (plan d'équipement).
-   R10. Dans le cas où la construction de la stratégie de transition post-quantique et/ou sa mise en œuvre sont externalisées, s'assurer que les décisions prises soient en accord avec les recommandations de l'ANSSI (choix des algorithmes par exemple), que l'analyse prenne en compte l'ensemble du périmètre de l'entité, même si la transition post-quantique peut être faite segment par segment, et qu'une gouvernance et un suivi de l'avancement de la transition post-quantique soient mis en place. L'accès aux données et aux équipements par le prestataire doit par ailleurs être encadré.
-  R11. Privilégier l'achat de produits intégrant de la PQC à partir de 2030 et, lorsque cela est possible, le déploiement de solutions ayant obtenu le Visa de sécurité de l'ANSSI.
-   R12. S'assurer de la prise en compte de la PQC par les fournisseurs, par exemple via des accords ou des contrats de niveau de service, garantissant, entre autres, une crypto-agilité, ou *a minima* s'assurer qu'ils disposent d'une feuille de route PQC.

3. Mise en œuvre de la stratégie de transition post-quantique

-  R13. Allouer les moyens (financiers et humains) suffisants pour permettre une transition post-quantique dans les meilleurs délais.
-  R14. Migrer vers des mécanismes cryptographiques résistants à la menace quantique conformes aux recommandations de l'ANSSI. En particulier, mettre en œuvre des mécanismes hybrides⁹ le cas échéant¹⁰.
-  R15. Mener des cycles de test et de validation : interopérabilité, performance, sécurité. Faire des tests systématiques de charge et compatibilité de PQC sur les équipements, mais aussi de configuration cryptographique.
-   R16. Mettre en œuvre des mesures compensatoires pour les actifs qui ne pourront pas être migrés dans des délais acceptables.
-   R17. Mettre en place des métriques adaptées au contexte pour mesurer objectivement l'avancement de la transition post-quantique.

⁹ Faute de recul encore suffisant, plusieurs algorithmes post-quantiques ont subi des attaques classiques au cours des dernières années.

¹⁰ Les recommandations de l'ANSSI en matière d'hybridation peuvent être retrouvées ici : <https://cyber.gouv.fr/enjeux-technologiques/cryptographie-post-quantique>.

4. Gouvernance continue de la cryptographie



R18. Mettre en place une gouvernance continue à deux niveaux : une gouvernance stratégique (comité de direction, conseil d'administration, comité des risques, etc.) sur un rythme annuel, et une gouvernance opérationnelle ou technique sur un rythme mensuel ou trimestriel.



R19. Assurer un suivi de la mise en œuvre de la stratégie de transition post-quantique, le mettre à jour au besoin.



R20. Surveiller l'évolution des menaces, et adapter les mécanismes cryptographiques au fil du temps.

Annexe 1 – Glossaire

Cryptanalyse quantique : La cryptanalyse est une technique qui consiste à déduire l'information en clair d'une information chiffrée sans posséder la clé de chiffrement ou à contrefaire la signature d'une information sans disposer de la clé de signature. La cryptanalyse quantique permettrait de faire tomber la cryptographie asymétrique actuelle.

Crypto-agilité : La crypto-agilité consiste en la capacité à mettre à jour les algorithmes cryptographiques, dans le cas où la sécurité apportée par ces algorithmes se révélerait insuffisante.¹¹

Cryptographie : La cryptographie traite de la protection de la sécurité des informations numériques à l'aide de transformations de ces dernières (indifféremment appelées algorithmes ou mécanismes cryptographiques) qui font intervenir des paramètres secrets appelés clés. La cryptographie possède aussi d'autres applications telles que l'authentification et la signature (numérique) des messages, ayant toutes pour finalité – chiffrement compris – le traitement, le stockage ou la transmission sécurisée de données.¹²

Cryptographie post-quantique : La cryptographie post-quantique, ou *post-quantum cryptography* en anglais (PQC), consiste en un ensemble d'algorithmes cryptographiques comprenant les établissements de clés et les signatures numériques et assurant une sécurité contre la menace quantique, en plus d'offrir une sécurité face aux attaques classiques.¹³

Déchiffrement : Le déchiffrement consiste à transformer des données chiffrées en données intelligibles à l'aide de la clé de déchiffrement. A distinguer du décryptement qui consiste à retrouver des données intelligibles à partir de données chiffrées sans disposer de la clé légitime.¹⁴

Hybridation : L'hybridation consiste à combiner des algorithmes de cryptographie asymétrique post-quantique avec des algorithmes de cryptographie asymétrique classique bien connus et bien étudiés ou avec l'emploi de clés symétriques pré-partagées, à des fins de non-régression¹⁵ de la sécurité classique de la cryptographie.

Ordinateur quantique, ou CRQC (Cryptographically Relevant Quantum Computer) : Un CRQC est un ordinateur quantique capable d'implémenter des instances pertinentes de l'algorithme de Shor et ainsi de menacer la cryptographie à clé publique déployée aujourd'hui. Les ordinateurs quantiques sont des calculateurs reposant sur des principes physiques fondamentalement différents des ordinateurs classiques actuels. Si de tels ordinateurs de grande taille sont un jour construits, ils pourraient effectuer certaines tâches beaucoup plus rapidement que ces derniers. La Commission européenne estime probable qu'un CRQC soit opérationnel d'ici 2040.

¹¹ Cryptographie post-quantique – FAQ de l'ANSSI : <https://cyber.gouv.fr/cryptographie-post-quantique-faq>.

¹² Le CyberDico de l'ANSSI : <https://cyber.gouv.fr/le-cyberdico>.

¹³ Rapport d'activité 2024 de l'ANSSI : <https://cyber.gouv.fr/publications/rapport-dactivite-2024-de-lanssi>.

¹⁴ Guide des mécanismes cryptographiques de l'ANSSI : https://cyber.gouv.fr/sites/default/files/2021/03/anssi-guide-mecanismes_crypto-2.04.pdf.

¹⁵ Cryptographie post-quantique – FAQ de l'ANSSI : <https://cyber.gouv.fr/cryptographie-post-quantique-faq>.

Annexe 2 – Critères de priorisation des actifs

Pour objectiver la priorisation des actifs, des critères sont proposés ci-dessous. Ils peuvent être regroupés en deux catégories : des critères principaux, très discriminants (criticité et longévité des actifs), et des critères pondérateurs, permettant l'ajustement de la priorisation initiale (exposition des données et des systèmes et complexité de la migration des actifs). Ils sont exprimés ici sous forme de questions et peuvent être utilisés par les organisations pour faciliter la construction de la stratégie de transition post-quantique.

Criticité des actifs

La criticité d'un actif dépend des conséquences de sa compromission, et de la sensibilité des données qu'il traite :

- Les données traitées sont-elles sensibles du point de vue de la loi ?
- S'agit-il de communications ou de systèmes critiques ?
- En-dehors des actifs classifiés, existe-t-il des actifs non classifiés mais stratégiques pour l'entité ?
- Quelle serait la nature de l'impact en cas de compromission du système ?
- La migration d'autres systèmes ou équipements dépend-elle de la migration de celui-ci ?
- La coordination, voire la synchronisation, de la migration d'actif avec d'autres acteurs est-elle nécessaire pour éviter toute interruption de service ?

Longévité des actifs

Plus la durée de conservation d'une donnée est longue, plus celle-ci doit être prioritaire, en raison des attaques rétroactives. De même, plus la durée de vie d'un système est longue, plus celui-ci devra être prioritaire, à moins qu'il ne puisse facilement être mis à jour.

- Quelle est la durée de vie de cet actif ?
- Une réglementation spécifique impose-t-elle des contraintes particulières (délais, protocoles ou contrôles) ?

Exposition des données ou des systèmes

Les données sensibles et les systèmes en traitement doivent être priorisés en fonction de leur exposition. Leur niveau de priorité varie selon s'ils sont accessibles à distance ou s'ils sont protégés par des mécanismes d'authentification post-quantiques par exemple. Dans le cas de systèmes obsolètes, dits *legacy*, le risque peut être accepté si ceux-ci sont difficilement accessibles par des attaquants et s'ils sont isolés du reste du réseau :

- La donnée ou le système considéré est-il accessible à distance ou exposé sur Internet ?

- La donnée ou le système est-il protégé par un mécanisme d'authentification post-quantique ?
- Est-il nécessaire de maintenir des systèmes obsolètes existants (ou systèmes *legacy*) ? Si oui, sont-ils accessibles à distance ?

Complexité de la migration des actifs

La complexité de la migration d'un actif impacte son niveau de priorité. En effet, un actif dont la migration est longue et/ou coûteuse ou impliquant un haut niveau technique (par exemple un système hétérogène ou distribué) doit être prioritaire pour s'assurer d'achever sa transition post-quantique au plus vite :

- Le système est-il composé de nombreux modules cryptographiques différents ?
- Les mécanismes cryptographiques sont-ils maîtrisés ?
- Le système ou les données sont-ils accessibles facilement ?
- Le volume de données à migrer est-il compatible avec la planification (volume conséquent et temps de traitement se chiffrant en années) ?
- Quelle est la durée de migration estimée du système ?
- L'actif peut-il être migré avec une simple mise à jour ou nécessite-t-il d'être remplacé ?
- Est-il nécessaire de repenser entièrement l'infrastructure (changements majeurs de fonctionnement, de ressources ou de fournisseurs) ?
- Est-il possible/nécessaire de maintenir l'activité pendant la migration ?
- Est-il possible de faire évoluer les composants cryptographiques du système ?
- Est-il possible de passer dans un mode hybride (conçus pour supporter à la fois l'algorithme classique et le post-quantique) ?
- Est-il possible de faire des « retours en arrière » (*rollbacks*, gestion du *versioning*) si besoin, et de gérer les mises à jour cryptographiques de façon flexible ?
- Les algorithmes standards sont-ils utilisés et est-il possible d'effectuer leurs mises à jour ?

Annexe 3 – Ressources documentaires

Pour aller plus loin, ci-dessous une sélection de ressources documentaires :

Publications de l'ANSSI

Page dédiée à la PQC : <https://cyber.gouv.fr/en/publication/anssi-views-on-the-post-quantum-cryptography-transition>

FAQ sur la PQC : <https://cyber.gouv.fr/enjeux-technologiques/cryptographie-post-quantique/faq-pqc/>

Transition Post-Quantique de SSHv2 :

<https://messervices.cyber.gouv.fr/guides/Transition-post-quantique-protocole-SSHv2>

Transition Post-Quantique d'IPsec :

<https://messervices.cyber.gouv.fr/guides/Transition-post-quantique-protocole-IPsec>

Transition Post-Quantique de TLS 1.3 :

<https://messervices.cyber.gouv.fr/guides/Transition-post-quantique-protocole-TLS-1-3>

ANSSI views on crypto agility :

<https://messervices.cyber.gouv.fr/guides/ANSSI-views-on-crypto-agility>

Avis de l'ANSSI sur la migration vers la cryptographie post-quantique :

<https://cyber.gouv.fr/publications/avis-de-lanssi-sur-la-migration-vers-la-cryptographie-post-quantique-0>

Follow up position paper on Post-Quantum Cryptography :

<https://messervices.cyber.gouv.fr/guides/en-follow-position-paper-post-quantum-cryptography>

Mécanismes cryptographiques :

<https://messervices.cyber.gouv.fr/guides/mecanismes-cryptographiques>

Publications internationales en co-portage

A Coordinated Implementation Roadmap for the Transition to Post-Quantum Cryptography : <https://cyber.gouv.fr/nous-connaître/publications/publications-internationales/a-coordinated-implementation-roadmap-for-the-transition-to-post-quantum-cryptography/>

Securing Tomorrow, Today: Transitioning to Post-Quantum Cryptography : <https://cyber.gouv.fr/nous-connaître/publications/publications-internationales/securing-tomorrow-today-transitioning-to-post-quantum-cryptography/>

Position Paper on Quantum Key Distribution : <https://cyber.gouv.fr/nous-connaître/publications/publications-internationales/position-paper-on-quantum-key-distribution/>

Publications externes d'intérêt pour l'écosystème

Feuille de route européenne pour la mise en œuvre coordonnée de la transition vers la PQC : <https://digital-strategy.ec.europa.eu/en/library/coordinated-implementation-roadmap-transition-post-quantum-cryptography>

Programme Digital Europe – soutien financier aux solutions facilitant la transition PQC : https://commission.europa.eu/funding-tenders/find-funding/eu-funding-programmes/digital-europe-programme_en

PQC migration handbook : <https://publications.tno.nl/publication/34643386/fXcPVHsX/TNO-2024-pqc-en.pdf>